

The Interchange

A federated data exchange for Kenyan lenders. Unified, secure exchange between organisations that remain competitors — brokered, never pooled; tokenised at the edge, never in the middle.

PREPARED BY	DATE	STATUS	SUPERSEDES
Faith Birgen	21 August 2026	Draft for decision	—

01

The argument in one page

Six systems are live. The next thing to build is not a seventh system — it is the road between companies.

The Micro-Eazy suite works because of one discipline: *nothing was migrated*. The connected-suite architecture computed the joins rather than copying the data, and it held — 93,376 rows of `CollectionTracker` joined to `Loans` with zero orphans, across two databases nobody had ever put in the same query. That is the entire thesis of this document, widened from two databases inside one company to ten companies inside one ecosystem.

The Interchange is the data layer that widens it. Ten lenders already running on infrastructure you administer, each holding a book the others cannot see, all of them lending to overlapping populations in the same city. None of them knows when a borrower who is current with them took a fourth loan somewhere else last Tuesday. The Interchange makes that one fact knowable — in under half a second, without any lender surrendering a borrower record to anyone.

13	10	3	6
HOSTS IN THE ESTATE	DATABASE SERVERS	ON THE TAILNET TODAY	ANSWERING SQL ON THE OPEN INTERNET

WHAT IS BEING PROPOSED

A two-plane architecture, following the X-Road model for the transactional plane and a modern lakehouse for the analytical one. Real-time member-to-member queries are brokered, signed and logged, and never pooled. Analytical data is tokenised inside each member's own perimeter before it moves, so the shared lake holds no identity that can be reversed. The launch product is **Interchange Exposure** — an instant multi-lender exposure check, offered on reciprocity: you may query only what you contribute to.

WHAT IT COSTS

Roughly **USD 60–90 per month** in infrastructure for the entire ecosystem, because the design leans on Cloudflare R2's zero egress fees, a single-binary Kafka-compatible broker,

and query engines that are processes rather than clusters. The expensive parts of this project are governance and law, not compute.

READ THIS BEFORE ANYTHING ELSE

Six production SQL Servers in this estate accept connections from the public internet today, and nine production credentials sit in cleartext in a git-tracked `appsettings.json`. Both must be closed before a single outside company is invited in. Section 3 sets out the order of work. This is not a footnote to the plan — it is Phase 0, and it is also the most persuasive thing you can offer a prospective member: *we will take your database off the public internet, and give you a network score in return.*

The estate as it stands

Every host below was found by sweeping all eleven projects in `c:\GIT` for connection endpoints, then probed for reachability on 21 August 2026. Reachability was tested from this workstation; "open" means the TCP port completed a handshake from the public internet without a VPN.

TABLE 1 · DATABASE AND APPLICATION HOSTS ACROSS ALL ELEVEN PROJECTS

#	HOST	TENANT / ROLE	TAILNET	PUBLIC PORT
1	102.210.148.124:4230 → 100.72.35.56	Micromart — Serviceconnect, CollectBox, Transactions	YES · SERVICES	N/A
2	213.148.17.54:4420	ServiceSuite / Axe — Serviceconnect, Notifications	YES	CLOSED
3	213.148.17.198:4420	"alaf" — Serviceconnect	NO	OPEN
4	213.148.17.228:4420 213.148.17.228:420	ConnectBox; FastDial call-centre	NO	OPEN
5	45.150.188.26:4420	Serviceconnect + TenderHub	NO	OPEN
6	102.214.69.233:4410 102.214.69.233:420	CollectBox v3 + the IIS box behind servicesuitecloud.com	NO	OPEN
7	102.220.22.84:50004	"cemes" — Serviceconnect	NO	OPEN
8	172.174.241.59:1433	SERVICESUITE (Azure)	NO	DORMANT
9	130.49.168.109:1433	ServiceSuiteV3 — test	NO	OPEN
10	34.70.119.63:4420	Legacy GCP. referenced in web.config	NO	DEAD
11	Supabase · eu-west-1	BirgenAI LMS Postgres	MANAGED	N/A
12	Vercel	The six front doors	MANAGED	N/A
13	arch-bishop	Your workstation — currently the relay for all six live systems	YES · SELF	FUNNEL :443

The tailnet today

Seven machines, of which three carry databases the ecosystem depends on.

TABLE 2 · TAILSCALE NODES, TAIL10C441.TS.NET

NODE	ADDRESS	STATE	ROLE
services	100.72.35.56	Online · direct	Micromart SQL — :4230 confirmed reachable
axemicro	100.103.154.73	Online	SQL — :4420 reachable
servicesuite-in	100.115.241.36	Online	SQL — :4420 reachable
vmi3298281	100.125.245.79	Online	Web/RDP only — :80 :443 :3389. Free capacity.
lms	100.92.236.116	Online	No service ports open
arch-bishop	100.79.242.78	Online · self	Workstation; Funnel ingress for all six systems
DESKTOP-F0A546R	100.117.191.0	Offline 7 days	Unattributed — audit or remove

Three findings

FINDING 1 · EXPOSED SURFACE

Six SQL Servers complete a TCP handshake from the open internet: 213.148.17.198, 213.148.17.228, 45.150.188.26, 102.214.69.233, 102.220.22.84 and 130.49.168.109. Notably 213.148.17.54 — the busiest connection string in the codebase — is *already* closed and reached over the tailnet. That is the pattern to replicate across the other six.

FINDING 2 · CREDENTIALS IN VERSION CONTROL

`ServiceSuite-Portal/ServiceSuite/appsettings.json` lines 10–31 hold nine production connection strings in cleartext, commented in and out by hand to switch tenants. Every one of those passwords must be treated as compromised and rotated. Tenant selection belongs in the existing encrypted `OrgIntegration.configEnc` vault, which the LMS already implements — the pattern exists, it simply has not reached this file.

FINDING 3 · THE LAPTOP IS A SINGLE POINT OF FAILURE

All six live systems relay through `arch-bishop` via Tailscale Funnel. Ten member organisations cannot depend on your workstation being awake. `vmi3298281` is already on the tailnet, already serving `:80/:443`, and carries no database — it is the obvious permanent home for the relay and for the Interchange Registry.

Phase 0 — securing the estate

Nothing in this blueprint may begin until the estate is defensible. This work is unglamorous, takes about two weeks, and is a precondition for every conversation with a prospective member.

Each server follows the same four steps, in this order, so that connectivity is proven before exposure is removed:

- 1 **Join the tailnet.** Install Tailscale, tag the node `tag:interchange-db`, and confirm it appears in `tailscale status`.
- 2 **Prove the private path.** Repoint one non-critical application to the `100.x` address and confirm a successful query. The Micromart cutover from `102.210.148.124` to `100.72.35.56` is the worked example — follow it exactly.
- 3 **Close the public port** at the host firewall and at the provider's edge. Re-run the reachability probe from off-network to confirm the handshake now fails.
- 4 **Rotate the credential** that was previously exposed, and move it into the encrypted vault.

TABLE 3 · ORDER OF WORK, HIGHEST RISK FIRST

ORD	HOST	WHY THIS POSITION	OWNER
1	102.214.69.233	Two open SQL ports <i>and</i> it is the public web host for <code>servicesuitecloud.com</code> . Largest blast radius.	You
2	213.148.17.198	Live tenant book, open to the internet, no compensating control.	You + tenant IT
3	213.148.17.228	ConnectBox and FastDial both depend on it; two ports open.	You
4	45.150.188.26	Carries Serviceconnect <i>and</i> TenderHub — two products, one exposure.	You
5	102.220.22.84	Live tenant, non-standard port offers no protection.	You + tenant IT
6	130.49.168.109	Test data, but a real credential and a real foothold.	You
7	34.70.119.63	Dead. Remove the reference from <code>web.config</code> and decommission.	You
8	172.174.241.59	Dormant. Confirm ownership, then decommission or enrol.	You

Two further Phase 0 tasks run in parallel: migrate the Funnel relay from `arch-bishop` to `vmi3298281`, and audit or remove `DESKTOP-F0A546R`, which has been offline for a week and belongs to no documented role.

Architecture — the two planes

X-Road is a transaction broker, not a data platform. Understanding what it does *not* do is what makes this design correct.

X-Road routes signed, timestamped, access-controlled request/response messages between organisations. It has no opinion about analytics, no bulk transfer, no streaming, no storage. Most teams that adopt it try to make it carry their data warehouse and fail. The Interchange therefore separates two planes that must never be conflated:

- **Plane A — the road.** Real-time, member-to-member, brokered queries. Follows the X-Road model. Nothing is pooled; each answer is computed live by the member who owns the data.
- **Plane B — the lakehouse.** Asynchronous, tokenised, analytical. Feeds scoring, benchmarking and early warning. Holds no reversible identity.

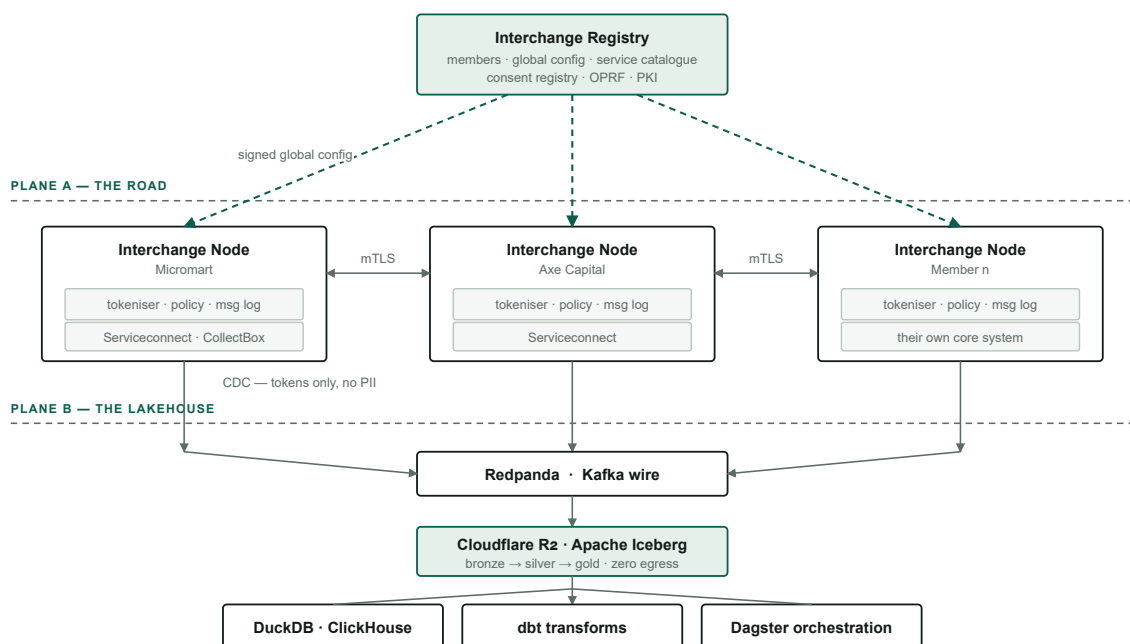
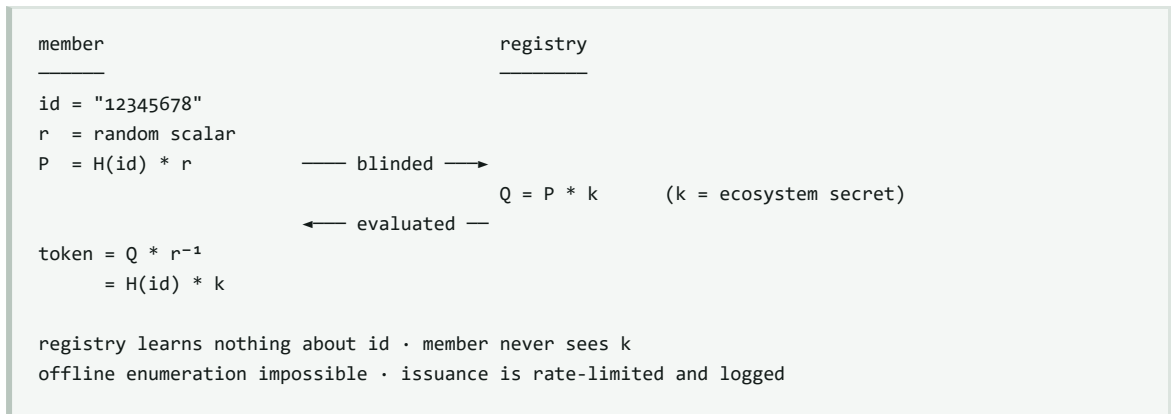


Figure 1 · Plane A brokers live queries between members; Plane B carries only tokenised feeds. The tokeniser sits inside each member's node, so identity is destroyed before anything crosses a boundary.

4.1 The tokenisation boundary

This is the decision the whole design rests on, and it is where most shared-data projects quietly fail. If each member tokenises with its own secret, tokens never match and exposure is impossible. If all members share one common secret, then a single compromised member can take the secret offline and enumerate every national ID in Kenya — the identifier space is small enough to brute-force in hours. Both of the obvious answers are wrong.

The Interchange uses an **oblivious pseudo-random function** (OPRF, RFC 9497 over ristretto255). The member blinds the identifier locally and sends the blinded point to the Registry; the Registry applies the ecosystem secret and returns the result; the member unblinds it to obtain the token. The Registry never learns the identifier, and the member never learns the secret — so no participant can compute tokens offline, and the Registry rate-limits every member's token issuance.



WHY THIS MATTERS COMMERCIALY

This is the difference between a product and a liability. Under the Data Protection Act 2019 a tokenised identifier that no participant can reverse is materially easier to defend than a pooled register of borrower identities — and it is the argument that will persuade a competitor to join a network operated by a company that also builds lending software.

4.2 What runs on a member's node

TABLE 4 · INTERCHANGE NODE COMPONENTS

COMPONENT	RESPONSIBILITY
Ingress / egress proxy	Mutual TLS in both directions. Member identity expressed as KE/LENDER/3005/exposure-v1 , following X-Road's member/subsystem/service convention so the envelope stays compatible if you later adopt the reference implementation.
Tokeniser	Runs the OPRF exchange. Never emits a raw identifier past this boundary — for Plane A queries or Plane B feeds.
Policy engine	Access rights per service, per counterparty. Enforces reciprocity: a member that stopped contributing stops being able to query.
Message log	Append-only, hash-chained, batch-timestamped against a public RFC 3161 authority. Gives every member the ability to prove what they did and did not send.
Query broker	Fans out exposure queries, applies per-member timeouts, aggregates, degrades to partial: true rather than failing.
CDC agent	Debezium against SQL Server change data capture, publishing tokenised rows to Plane B. services already runs SQL Server 2022 Enterprise, so CDC is available today.

Interchange Exposure — the launch product

“Is this borrower, who looks clean to me, currently servicing four other loans across this ecosystem?”

Kenyan credit reference bureau data is expensive per query and lags by weeks. The Interchange answers the same question from live books in under half a second, and answers it free at the point of use to any member who contributes. That asymmetry — instant and live versus slow and paid — is what makes lenders join.

5.1 How a query travels

- 1 The lender's origination system calls its *own* node: `POST /exposure` with national ID, MSISDN and a consent reference.
- 2 The node obtains `subject_token` via the OPRF exchange with the Registry.
- 3 The node checks the **Bloom filter digests** — every member publishes a filter of its active-borrower tokens to R2 every fifteen minutes. Typically this narrows a ten-member fan-out to one or three real calls.
- 4 Signed queries go only to members with a probable hit, over mTLS, with a 250 ms timeout each and full parallelism.
- 5 Each responding member returns **aggregates only** — count of active loans, outstanding band, worst arrears bucket, most recent disbursement date. Never a borrower record. Never the lender's identity, unless both parties have enabled mutual disclosure.
- 6 The requesting node aggregates, timestamps, writes to its message log, and returns. Every queried member receives an audit entry.

```
POST /exposure      →  { national_id, msisdn, consent_ref }

{
  "subject_token": "a4f1...",           // never reversible
  "as_of":        "2026-08-21T09:14:22Z",
  "active_loans": 4,
  "lenders":      3,
  "outstanding_band": "50k-100k",       // banded, not exact
  "worst_bucket":  "watch_2",
  "newest_disbursement": "2026-08-19",
  "velocity_14d":  2,                   // ← the signal that matters
  "partial":       false,
  "responded":     3,
  "queried":       3
}
```

THE DESIGN DETAIL WORTH DEFENDING

Bloom filter pre-screening is not only a latency optimisation. Without it, every exposure query broadcasts to all ten members that a named token is being evaluated — which leaks a member's origination pipeline to its competitors. Filtering locally means most members never learn the query happened at all.

5.2 What follows Exposure

TABLE 5 · THE PRODUCT LADDER

PRODUCT	WHAT IT IS	DEPENDS ON
Exposure	Live multi-lender exposure and stacking velocity.	Plane A only — ships first
Signals	Push alert when an existing borrower takes credit elsewhere. Converts collections from reactive to pre-emptive.	Plane A + subscriptions
Bench	Anonymised portfolio benchmarking — your PAR-30 against the ecosystem median and top quartile.	Plane B, ~1 month of data
Score	Network credit score fusing ecosystem repayment history with the existing M-Pesa thin-file cruncher.	Plane B, 3–6 months of data
Recover	Collections intelligence — best contact hour, promise-to-pay propensity, alternate numbers seen elsewhere. Built on the 1.34 M call dispositions and 150 K PTPs already in CollectBox.	Plane B + consent extension

RECIPROCITY IS THE BUSINESS MODEL

Contribution and consumption are bound in the policy engine, not in a contract clause. A member who stops publishing stops being able to query, automatically, within one configuration cycle. This is the mechanism that has made every successful contributory bureau work, and it is the reason a network of competitors can be stable.

Tooling and cost

Every choice below is open source or has a free tier that covers the first ten members. The selection is driven by one constraint that dominates all others at this scale: **egress fees**. Ten members pulling analytics daily out of S3 would cost more than the rest of the stack combined; R2 charges nothing for it.

TABLE 6 · STACK SELECTION

LAYER	CHOICE	WHY THIS AND NOT THE OBVIOUS ALTERNATIVE	MONTHLY
Object storage	Cloudflare R2	Zero egress. S3 <code>af-south-1</code> is closer to Nairobi but charges per gigabyte out, which is exactly the access pattern this ecosystem has.	~\$12
Table format	Apache Iceberg	Schema evolution and time travel matter when ten members change their schemas without telling you. R2 Data Catalog removes the need to run Nessie or Polaris.	included
Streaming	Redpanda	Kafka wire-compatible in a single binary — no JVM, no ZooKeeper, no cluster. At fifty members, swap in Kafka proper without changing a producer.	~€8 VPS
Capture	Debezium	SQL Server CDC is already available on <code>services</code> (2022 Enterprise). Log-based capture means no triggers and no load on the lending book.	included
Transform	dbt + DuckDB	Transforms run as a process against Iceberg on R2. No warehouse to keep warm, no idle spend.	—
Orchestration	Dagster	Asset-based lineage answers “where did this number come from”, which is the first question every member auditor asks. Airflow models tasks; you need to model data.	~€8 VPS
Serving	ClickHouse	Only when query concurrency outgrows DuckDB. Defer until it does.	~€15 when needed
Transport	Tailscale	Already proven on the Micromart cutover. Removes the six exposed SQL ports without touching any application.	~\$6/user
Node runtime	Go	Single static binary a member's IT team can run without installing a runtime. That matters more than language preference when you are asking ten companies to host something.	—

\$60–90 TOTAL MONTHLY INFRA, TEN MEMBERS	<400ms P95 EXPOSURE QUERY TARGET	0 RAW IDENTIFIERS CROSSING A BOUNDARY	15min BLOOM FILTER REFRESH
--	---	---	--------------------------------------

6.1 On Kafka

Kafka is the correct long-term answer and the reason the wire protocol is non-negotiable — but running a Kafka cluster for ten members' change feeds is operational cost with no return at this stage. Redpanda speaks the same protocol from one binary. When throughput or membership justifies the cluster, the migration is a broker swap, not a rewrite. Choosing the protocol now and deferring the cluster is the discipline; adopting the cluster now would be the mistake.

6.2 On X-Road

The decision taken is to implement X-Road's *model* — member and subsystem identity, mutually authenticated transport, signed messages, timestamped append-only logs, a central registry distributing signed global configuration — as a lightweight Go node, rather than deploying the reference implementation. The reference implementation requires a Central Server, a Security Server per member, and a trust-services estate (CA, OCSP responder, time-stamping authority) that is disproportionate for ten lenders.

The constraint that makes this reversible is the envelope: keep the message format and identity scheme X-Road-compatible from the first commit. Any member who later demands the certified implementation can then run a real Security Server against the same ecosystem, and the migration is a deployment question rather than a redesign.

Onboarding a member

Ten companies will not all have the same capability. The node supports four ingestion tiers, and a member can start at the bottom and climb.

TABLE 7 · INGESTION TIERS

TIER	MECHANISM	SUITS	LATENCY
T0	Tailnet + read-only SQL user	Members already on your infrastructure — Micromart and Axe today	Real time
T1	Node with Debezium CDC	The target state for every member	Seconds
T2	Node polling a view or stored procedure	Members who will not enable CDC	Minutes
T3	Signed batch upload to R2	Members with no database access to give	Daily

A member joining follows the same sequence regardless of tier: certificate issuance and registration in the Registry; deployment of the node inside their perimeter; mapping their schema to the canonical model through a versioned data contract held in git; a shadow period where they contribute but cannot query; then activation.

THE SHADOW PERIOD IS NOT OPTIONAL

Two to four weeks of contribution before query rights are granted does two things: it proves the member's feed is accurate before anyone relies on it, and it establishes reciprocity as a lived norm rather than a clause. Members who query from day one never build the contribution habit.

Law, governance, and the risk that could stop this

UNRESOLVED — OBTAIN COUNSEL BEFORE PHASE 2

Kenya regulates the sharing of credit information between institutions. The Credit Reference Bureau Regulations made under the Banking Act govern bureau activity, and a service that tells one lender about another lender's exposure may be construed as falling within that regime. **This is the single largest risk to the plan**, and it is a question for a Kenyan financial services lawyer, not for an architecture document.

Three paths are worth putting to counsel: operating strictly as a data processor acting on documented borrower consent on behalf of each member; licensing through or partnering with an already-licensed bureau; or seeking written guidance from the regulator before launch. Resolve this before building Plane A, not after.

DATA PROTECTION

Registration with the Office of the Data Protection Commissioner is required, and the controller/processor determination must be made deliberately — the tokenisation boundary in §4.1 is what makes the processor argument credible. Borrower consent must be captured at origination, referenced by every query, and revocable; the consent registry in the Registry component exists for this.

WHO OPERATES IT

BirgenAI operating the Interchange while also supplying lending software to some members is a conflict a competitor will name in the first meeting. Consider a separate legal entity with member representation on its governing body. It costs little now and is very hard to retrofit once ten companies have joined something you own outright.

RESIDENCY

R2 offers no Nairobi region. If any member or the regulator requires in-country residency for tokenised data, the fallback is a self-hosted MinIO cluster on Kenyan infrastructure behind the same Iceberg interface — a swap the architecture already permits, at meaningfully higher cost. Establish this requirement before committing to R2, not after loading a terabyte.

Phasing

TABLE 8 · DELIVERY PLAN

PHASE	WINDOW	DELIVERABLE	DONE WHEN
0	Weeks 1–2	Secure the estate. Six servers onto the tailnet, public SQL ports closed, credentials rotated out of git, relay moved to <code>vmi3298281</code> .	External probe finds zero open SQL ports
1	Weeks 3–6	Registry and the first node. OPRF service, PKI, message log, policy engine. Micromart and Axe enrolled.	Two nodes exchange a signed, logged message
2	Weeks 7–10	Exposure v1 live between two members. Bloom filter distribution, audit trail, member console.	p95 under 400 ms on real books
3	Weeks 11–16	Plane B. CDC from Micromart, R2 + Iceberg, dbt and Dagster, Bench shipped.	A member sees their PAR against the median
4	Months 5–6	Members three through ten. Signals and Score.	Ten contributing members
5	Months 7–12	Governance body stood up, Recover shipped, optional X-Road reference cutover.	Interchange operates independently of any one member

Phases 0 and 1 are sequential and non-negotiable. Phase 3 can begin in parallel with Phase 2 because the planes share only the tokeniser.

Naming and domains

The system is **The Interchange**; a participating organisation is a *member*; the software it runs is an **Interchange Node**; the central component is the **Interchange Registry**; the published services form the **Interchange Directory**.

TABLE 9 · DOMAINS

HOST	PHASE	SERVES
<code>interchange.servicesuitecloud.com</code>	Launch	Member console and Directory. Inherits the trust of the six live systems.
<code>registry.interchange.africa</code>	Phase 1	Registry API, global configuration, OPRF endpoint.
<code>interchange.africa</code>	Month 6	The permanent, vendor-neutral home.

MOVE OFF THE SERVICESUITE DOMAIN EARLY

Launching on `servicesuitecloud.com` is right — it borrows credibility you have already earned. But a lender is being asked to join a network that appears, by its domain, to belong to a company that sells to its competitors. Neutral branding is not cosmetic here; it is part of the trust architecture, and it should follow the same timeline as the governance entity in §8.

Decisions still open

- 1 **Regulatory position.** Counsel on the CRB Regulations question in §8. Blocking for Phase 2.

- 2 **Operating entity.** BirgenAI subsidiary, or a member-governed association? Affects every membership conversation, so decide before member three.
- 3 **Data residency.** Is in-country storage a hard requirement for any member or regulator? Determines R2 versus self-hosted MinIO. Blocking for Phase 3.
- 4 **Founding cohort.** Which three of the ten interested companies go first? Recommend the two already on the tailnet plus one genuine outsider — an ecosystem that only works for your own clients proves nothing.
- 5 **Commercial model.** Reciprocity governs access, but something must fund operations. Flat membership fee, per-query above a contribution-linked free tier, or bundled into ServiceSuite licensing?
- 6 **Node ownership.** Does the member run the node on their hardware, or do you host it for them? Materially changes the trust story and the support burden.

RECOMMENDED NEXT STEP

Begin Phase 0 immediately — it needs none of the decisions above, it removes the estate's worst risk, and every hour of it is work you would have to do regardless of whether the Interchange is ever built. Put the regulatory question to counsel in the same week.